

Bug Bounty Platform - Relatório Técnico de Vulnerabilidade

Exposição de Arquivos de Ambiente (.env)

Pesquisador: João Silva

1. Descrição Técnica

O servidor web proxy do sistema legado está configurado de maneira incorreta, não bloqueando o acesso direto a dotfiles na raiz do diretório público da aplicação.

2. Prova de Conceito (Passos para Reproduzir)

1. Acessar o domínio principal do sistema legado.
2. Requisitar a URI oculta via navegador ou terminal: GET https://legacy.techcorp.com/.env
3. O servidor ignora as diretivas de restrição e retorna o conteúdo em texto plano (MIME type text/plain).

3. Impacto

O arquivo contém as chaves de acesso a serviços em nuvem de terceiros (AWS, SendGrid) e as credenciais internas (DSN) do banco de dados, comprometendo a segurança de toda a infraestrutura de retaguarda.